Nexora Financial Services

Employee Information Security & Technology Usage Policy

Document ID: NFS-SEC-001
Version: 2.1
Effective Date: 1 September 2026
Classification: Internal
Policy Owner: Information Security & Risk Management

1. Purpose

This policy defines the security requirements employees and contractors of Nexora Financial Services must follow when accessing company systems, applications, devices, and confidential information.

The purpose of the policy is to reduce operational and information-security risk while ensuring employees can perform their responsibilities effectively.

2. Password Management

All corporate user accounts must use passwords containing at least **14 characters**.

Passwords must contain a combination of uppercase letters, lowercase letters, numbers, and special characters.

Employees must not share passwords with colleagues, managers, vendors, or support personnel.

Passwords must not be stored in unencrypted documents, spreadsheets, email messages, or personal note-taking applications.

If an employee suspects that a password has been compromised, the password must be changed immediately and the Information Security team must be notified.

3. Multi-Factor Authentication

Multi-factor authentication (MFA) is mandatory for:

- Remote access to corporate systems
- Administrative accounts
- Production environments
- Cloud management consoles
- Corporate VPN access

MFA must use an approved authentication mechanism.

SMS-based authentication should only be used when stronger authentication mechanisms are unavailable.

4. Remote Working

Employees working remotely may access corporate systems only through company-approved devices and approved secure connectivity mechanisms.

Employees accessing restricted corporate systems from outside the company network must use the corporate VPN.

Public or unsecured Wi-Fi should not be used to access confidential company information unless the connection is protected through the corporate VPN.

Employees must ensure that screens displaying confidential information are not visible to unauthorized individuals.

5. Company Devices

Company-issued laptops and mobile devices must have:

- Full-disk encryption enabled
- Endpoint protection enabled
- Automatic operating-system security updates enabled
- Screen-lock protection configured

Employees must not disable company-installed security software.

A company device that is lost or stolen must be reported to the Service Desk and Information Security team within **one hour of discovery**.

6. Confidential Data

Confidential customer or company information must only be stored in approved corporate systems.

Employees must not transfer confidential information to:

- Personal email accounts
- Personal cloud-storage services
- Unapproved USB storage devices
- Personal messaging applications

Customer financial information must never be copied into publicly accessible AI services.

7. Generative AI Usage

Employees may use company-approved Generative AI services for business activities.

Before confidential or restricted information is submitted to an AI system, the AI service must be explicitly approved for that data classification.

Employees must independently validate AI-generated content before using it for:

- Customer communication
- Regulatory submissions
- Financial decisions
- Production software changes

AI-generated content must not be treated as authoritative solely because it was generated by an approved AI system.

8. Production Access

Production access must follow the principle of least privilege.

Permanent administrative access to production environments is prohibited unless formally approved as part of an employee's operational responsibility.

Temporary privileged access should automatically expire after the approved access period.

Production access must be reviewed every **90 days**.

Access belonging to employees who leave the organization must be revoked within **four hours** of the confirmed termination time.

9. Security Incident Reporting

Employees must report suspected security incidents as soon as possible.

High-severity security incidents must be reported to the Security Operations Centre within **30 minutes of discovery**.

Examples include:

- Suspected account compromise
- Unauthorized production access
- Malware infection
- Loss of confidential customer information
- Suspicious data transfer

Employees must not attempt to conceal or independently investigate a security incident unless authorized by the Security Operations Centre.

10. Software Installation

Employees must only install software approved by the company's technology organization.

Unapproved browser extensions, remote-access software, peer-to-peer applications, and software downloaded from untrusted sources are prohibited.

Engineering teams may use open-source libraries provided they comply with the organization's software-composition and security-review requirements.

11. Data Retention

Security audit logs must be retained for a minimum of **365 days**.

Production application logs must be retained for at least **180 days**.

Customer transaction records must be retained according to applicable regulatory and legal requirements.

When the required retention period expires, data must be securely deleted according to the organization's data-disposal procedures.

12. Exceptions

Exceptions to this policy require documented approval from both the employee's business owner and Information Security.

An approved exception must specify:

- Business justification
- Systems affected
- Risk assessment
- Compensating controls
- Expiration date

Policy exceptions may not be approved indefinitely.

13. Compliance

Violations of this policy may result in removal of system access and may be handled under the organization's applicable disciplinary procedures.

Serious security violations may also require notification to Legal, Compliance, Risk Management, or relevant regulatory authorities.